

Cisco Secure Workload - COBIT 2019 Compliance Report

Cisco Secure Workload - COBIT 2019 Compliance Report

Customer-Facing Compliance Report

Framework: ISACA COBIT 2019 - Framework for the Governance and Management of Enterprise IT

Primary audience: IT governance, internal audit, risk management, and assurance teams using COBIT 2019 as the governance and management framework.

CSW positioning: Workload-level evidence inputs to COBIT objectives where the practice is technical: DSS05 (security services), APO13 (managed security), MEA01 (performance and conformance monitoring), and BAI06 / BAI10 (change and configuration evidence).

Framework Version Note

References COBIT 2019. Objective codes (e.g. APO13 Managed Security, DSS05 Managed Security Services, MEA01 Managed Performance and Conformance Monitoring, BAI06 Managed IT Changes) are stable in COBIT 2019. Validate scope tailoring against the customer's design factors and goals cascade.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The reference design (CSW-COBIT-2019-Technical-Reference design.md) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW “certifies” compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer’s compliance team, and the customer’s assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer’s governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

COBIT-2019

(no fixed scope tree; COBIT objective evidence is mapped across whichever CSW-instrumented scopes are in audit scope)

This scope pattern should be validated with the customer’s architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- DSS05.02 - Manage network and connectivity security (workload segmentation and policy enforcement)
- DSS05.03 - Manage endpoint security (workload-level allowlist input)
- DSS05.07 - Manage vulnerabilities (reachability-weighted CVE)
- APO13.01 - Establish and maintain an information security management system (workload-level inputs)
- MEA01.04 / MEA01.05 - Performance and conformance monitoring (continuous evidence)
- BAI06.01 - Evaluate, prioritise, and authorise change requests (workspace change log)
- BAI10.01 - Establish and maintain a configuration model (workspace baseline)

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- Governance objectives (EDM family)
- APO01-12 (organisational alignment, enterprise architecture, portfolio, financials, HR, relationships, service agreements, suppliers, quality, risk, security beyond technical, data, projects)

- BAI01-05 / BAI07-09 / BAI11 (organisational change, requirements definition, identification of solutions, availability, capacity, ITSM, organisational change enablement, knowledge, assets)
- DSS01 / DSS03 / DSS04 / DSS06 (managed operations, problems, continuity, business process controls)
- MEA02-04 (system of internal control, compliance with external requirements, assurance)

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
DSS05.02 - Network and connectivity security	Direct	Policy workspace + workload-to-workload allowlist	Workspace snapshot + observed-vs-approved flow comparison
DSS05.07 - Vulnerability management	Direct	Reachability-weighted CVE evidence	Prioritised remediation list
APO13 - Managed security (technical inputs)	Direct	Continuous workload telemetry + periodic evidence pack	Quarterly evidence bundle
MEA01.04 - Performance and conformance monitoring	Direct	Policy-violation log; drift evidence	Continuous evidence (replaces point-in-time samples)
BAI06 - Managed changes	Direct	Workspace change log (snapshots before/after each change)	Change-controlled policy workspace export
BAI10 - Managed configuration	Direct	Workspace baseline snapshots	Baseline configuration evidence

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Workload scope inventory	Workloads in COBIT audit scope by business function	Inventory + scope membership export	Monthly
Policy and change evidence	Workspace snapshot before/after each	Policy workspace export + change log	Per change + quarterly bundle

Topic	What to collect	CSW source	Suggested cadence
	authorised change		
Conformance monitoring evidence	Continuous policy-violation and drift evidence	Policy analysis output	Continuous; reviewed quarterly
Vulnerability + reachability	CVE list weighted by reach across in-scope workloads	Vulnerability report scoped to COBIT-2019	Monthly
Management review pack	Aggregated quarterly evidence bundle	Inventory + workspace + policy violation + vulnerability extracts	Quarterly

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. tenant, prototype, isa_level, np, cui, ephi).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not replace COBIT governance design, design-factor analysis, goals cascade, process ownership, risk appetite decisions, enterprise metrics ownership, audit judgement, or GRC workflow.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.